BÁO CÁO KỸ THUẬT

Trợ lý điều tra SOC dựa trên bằng chứng

Kiến trúc, phương pháp và đánh giá thực nghiệm

Dự án VinSOC

Nhóm phát triển VinSOC

Cập nhật ngày 15 tháng 10 năm 2026

Phạm vi: điều tra SOC có dẫn chứng, native tool calling và Text-to-SQL trên dữ liệu đã cấp

Tóm tắt

Báo cáo trình bày thiết kế và trạng thái thực nghiệm của VinSOC, một trợ lý hỗ trợ người phân tích Trung tâm Vận hành An ninh mạng (SOC) điều tra cảnh báo, chỉ báo xâm nhập và câu hỏi trên dữ liệu mạng. Giải pháp kết hợp mô hình ngôn ngữ với các công cụ CTI, phân tích flow, truy vết endpoint và Text-to-SQL; mọi kết quả được chuẩn hóa thành dẫn chứng có nguồn trước khi tạo nhận định và chuyển sang bước người phân tích duyệt. Mục tiêu là hỗ trợ điều tra có thể kiểm tra lại, thay vì tự động đưa ra quyết định xử lý sự cố.

Hai track đánh giá chính được tách theo chức năng. R1 đo quyết định gọi ba công cụ production trong một lượt. Bộ phát triển 24 ca đạt 22/24 case success, exact-call F1 95,08%, no-tool accuracy 100% và tool-set exact match 91,67%. Bộ generalization 120 ca đã được duyệt độc lập và khóa nhưng chưa có model run đủ mẫu. R2 đo Text-to-SQL bằng kết quả thực thi. Bộ lịch sử tám câu CTU đạt 7/8 execution accuracy, execution success và syntax validity; safety rejection quan sát được là 0/8. Trên calibration 24 câu đa lĩnh vực, cấu hình sinh SQL trực tiếp E0 đạt 15/24 execution accuracy, cao hơn cấu hình linker E3 đạt 5/24 trong lượt chọn cấu hình. Bộ evaluation 96 câu đã được thiết kế nhưng chưa có đủ kết quả để công bố điểm.

Phân tích cho thấy kiến trúc đã hình thành chuỗi điều tra có dẫn chứng và cơ chế thực thi dữ liệu chỉ đọc. Tuy nhiên, nhánh IOC cũ vẫn có thể đóng benign từ triage theo nội dung trước enrichment khi không cấu hình human review; phép phát hiện kết nối định kỳ chỉ tạo ứng viên C2; và các bộ đánh giá mở rộng chưa được chạy đầy đủ. Do đó, kết quả hiện tại chứng minh mức tích hợp và hiệu năng ở phạm vi phát triển, chưa đủ để tuyên bố hiệu quả điều tra đầu cuối hoặc khả năng khái quát trên 120 ca R1 và 96 câu R2.

Từ khóa: SOC, điều tra dựa trên bằng chứng, tool calling, Text-to-SQL, CTI, C2, human-in-the-loop.

Mục lục

Tóm tắt **2**
Danh mục từ viết tắt **4**
1 Giới thiệu **5**
1.1 Bối cảnh 5
1.2 Bài toán 5
1.3 Mục tiêu và câu hỏi đánh giá 5
1.4 Đóng góp và phạm vi 5
2 Cơ sở phương pháp **6**
3 Kiến trúc giải pháp **7**
4 Quy trình điều tra **8**
5 Công cụ và nguồn dữ liệu **10**
6 Thiết kế đánh giá **11**
7 Kết quả thực nghiệm **14**
8 Phân tích và thảo luận **16**
9 Ưu điểm, hạn chế và đe dọa tới tính hợp lệ **18**
10 Kế hoạch hoàn thiện **19**
11 Kết luận **20**
Tài liệu tham khảo **21**
Phụ lục A Ma trận trạng thái **21**
Phụ lục B Cách đọc các con số **22**

Danh mục từ viết tắt

Bảng 1. Các từ viết tắt sử dụng trong báo cáo

Từ viết tắt	Nghĩa
SOC	Security Operations Center - Trung tâm Vận hành An ninh mạng
CTI	Cyber Threat Intelligence - tình báo mối đe dọa mạng
IOC	Indicator of Compromise - chỉ báo xâm nhập
C2	Command and Control - hạ tầng chỉ huy và điều khiển
HITL	Human in the Loop - con người tham gia duyệt quyết định
R1	Track đánh giá quyết định gọi công cụ
R2	Track đánh giá Text-to-SQL bằng kết quả thực thi
EX	Execution Accuracy - độ chính xác theo kết quả thực thi
EM	Exact Match - khớp chính xác

1 Giới thiệu

1.1 Bối cảnh

SOC tiếp nhận lượng lớn cảnh báo, nhật ký và chỉ báo từ nhiều nguồn có mức tin cậy khác nhau. Người phân tích phải xác định câu hỏi cần trả lời, lựa chọn nguồn dữ liệu, đối chiếu thời gian và thực thể, rồi ghi lại căn cứ cho quyết định. Quy trình này tốn thời gian và dễ thiếu nhất quán khi bằng chứng nằm rải rác trong hệ thống CTI, lưu lượng mạng, telemetry endpoint và cơ sở dữ liệu sự kiện.

Mô hình ngôn ngữ có thể hỗ trợ diễn giải yêu cầu và lựa chọn công cụ, nhưng cũng có thể gọi sai nguồn, tự suy diễn tham số hoặc tạo truy vấn chạy được nhưng trả kết quả sai. Vì vậy, VinSOC được xây dựng theo hướng trợ lý điều tra có kiểm soát: mô hình đề xuất hành động trong phạm vi schema đã cấp; công cụ chỉ đọc dữ liệu; kết quả được ghi thành evidence; và quyết định xử lý cuối cùng thuộc người phân tích. Cách tiếp cận này phù hợp với nguyên tắc truy nguồn và vai trò con người trong xử lý sự cố [1].

1.2 Bài toán

Bài toán kỹ thuật gồm ba lớp liên quan nhưng cần đo riêng. Lớp thứ nhất là quyết định có cần gọi công cụ hay không và chọn đúng công cụ cùng tham số. Lớp thứ hai là thực thi tác vụ dữ liệu, trong đó Text-to-SQL phải tạo truy vấn an toàn và trả đúng kết quả. Lớp thứ ba là điều tra đầu cuối: kết hợp các kết quả thành nhận định có dẫn chứng, nêu giới hạn và đưa hồ sơ cho người phân tích duyệt. Việc gộp ba lớp vào một tỷ lệ duy nhất sẽ che giấu nguyên nhân lỗi và làm sai phạm vi kết luận.

1.3 Mục tiêu và câu hỏi đánh giá

Báo cáo trả lời bốn câu hỏi: (1) kiến trúc nào đã được triển khai để kết nối mô hình, công cụ và dẫn chứng; (2) hệ thống đang thực hiện enrichment, kiểm tra hành vi và human review ở mức nào; (3) R1 và R2 đã được đánh giá trên phạm vi nào và kết quả thực tế là bao nhiêu; (4) những hạn chế nào còn ngăn hệ thống được xem là một giải pháp điều tra SOC hoàn chỉnh.

1.4 Đóng góp và phạm vi

- Thiết kế một chuỗi xử lý từ yêu cầu điều tra đến tool call, evidence, assessment, verification và human review.
- Công khai chín công cụ được sử dụng theo từng profile, cùng phạm vi dữ liệu và giới hạn của từng công cụ.
- Tách R1, R2 và phép đo đầu cuối để mỗi kết quả giữ đúng mẫu số, hợp đồng và ý nghĩa thống kê.
- Chuẩn bị bộ generalization R1 gồm 120 ca và bộ R2 gồm 24 câu calibration cộng 96 câu evaluation, có khóa và kiểm tra offline.

- Giữ lại các lỗi thực tế, chi phí và giới hạn thay vì thay đổi gold hoặc loại ca để cải thiện điểm.

Phạm vi không bao gồm containment tự động, tác động lên hệ thống sản xuất, xác minh malware đầy đủ hoặc khẳng định một IP là C2 chỉ từ một đặc trưng lưu lượng. Các adapter Google SecOps, GTI và SCC mới là khung tích hợp và chưa được xem là kết nối production đã xác minh.

2 Cơ sở phương pháp

2.1 Điều tra SOC dựa trên bằng chứng

Một nhận định điều tra có giá trị khi người đọc truy ngược được về quan sát, nguồn dữ liệu, thời điểm và phạm vi truy vấn. VinSOC phân biệt evidence quan sát trực tiếp, evidence suy ra từ phép tính và intelligence bên ngoài. Assessment chỉ được tham chiếu các evidence ID đã lưu; verification kiểm sự tồn tại của liên kết và nêu các phần chưa được xác minh. Thiết kế này không loại bỏ sai số mô hình, nhưng làm cho sai số có thể kiểm tra và phân loại.

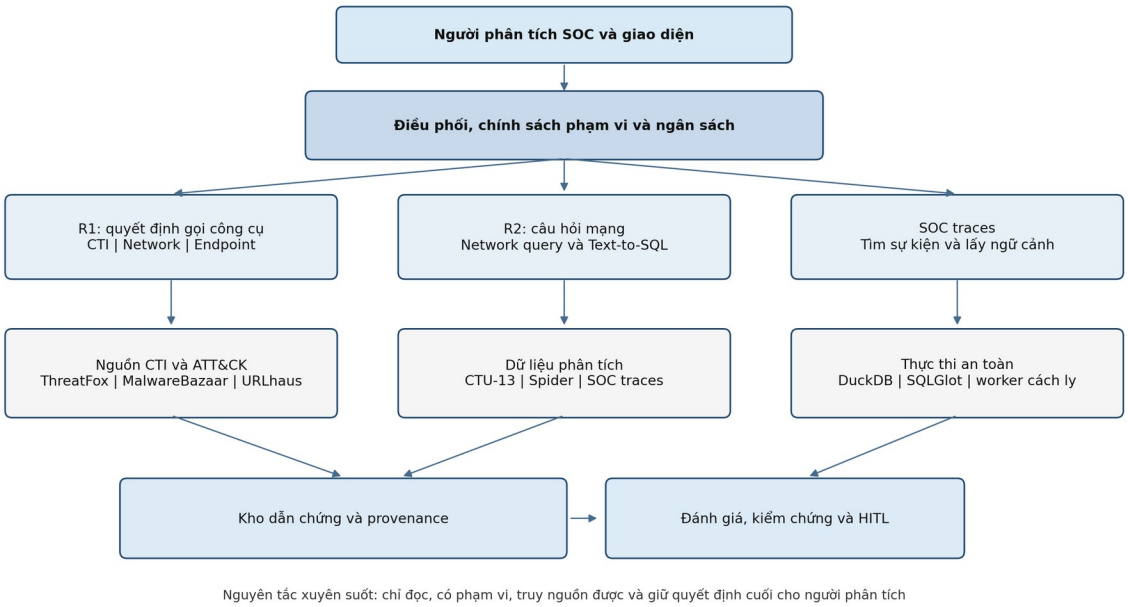
2.2 Tool calling

Native tool calling giới hạn mô hình trong tập hàm có schema. Chất lượng được đo bằng tập tool, số lời gọi, tham số bắt buộc và tham số quan trọng. Cách chấm theo lời gọi chính xác có liên hệ với cách tiếp cận của Berkeley Function Calling Leaderboard [5], nhưng benchmark R1 sử dụng ba schema production riêng của VinSOC nên điểm không thể xem là điểm BFCL chính thức.

2.3 Text-to-SQL

Text-to-SQL chuyển câu hỏi ngôn ngữ tự nhiên thành truy vấn trên schema được cấp. Exact string match không phù hợp vì nhiều truy vấn tương đương có cách viết khác nhau. R2 dùng execution accuracy làm chỉ số chính: chạy truy vấn dự đoán và gold trên cùng snapshot, sau đó so sánh kết quả theo hợp đồng thứ tự, multiset, NULL và sai số số học. Thiết kế dữ liệu đa lĩnh vực được gợi ý từ Spider [4], nhưng đã được thích nghi cho DuckDB và phạm vi VinSOC.

3 Kiến trúc giải pháp



Hình 1. Kiến trúc logic của trợ lý điều tra SOC dựa trên bằng chứng

3.1 Các lớp chính

Lớp tương tác nhận cảnh báo, IOC hoặc câu hỏi dữ liệu. Bộ điều phối xác thực phạm vi, chọn profile công cụ và quản lý lượt gọi. Lớp công cụ gồm ba công cụ production của R1, công cụ network_query của R2 và hai công cụ SOC traces dùng cho dữ liệu tổng hợp. Các service phía dưới truy cập nguồn CTI, flow, endpoint hoặc snapshot dữ liệu. Evidence store giữ nội dung, provenance và quan hệ giữa evidence. Assessment và verification chuyển hồ sơ sang human review.

3.2 Phân tách profile

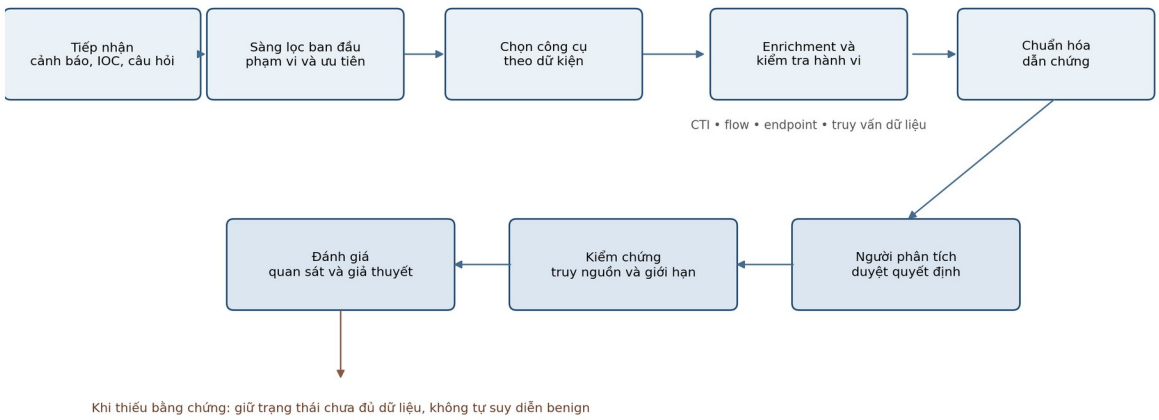
Các tool không được cấp đồng thời trong mọi lượt. Profile native tool calling chỉ có cti_enrichment, network_investigation và endpoint_investigation. Profile câu hỏi mạng dùng network_query, sau đó service R2 có thể gọi generator trực tiếp hoặc bộ công cụ database ở cấu hình linker. Profile SOC traces dùng soc_search_events và soc_get_context trên dataset tổng hợp. Phân tách này giảm không gian hành động và giúp scorer xác định đúng hợp đồng của từng track.

3.3 Nguyên tắc kiểm soát

Bảng 2. Các nguyên tắc thiết kế

Nguyên tắc	Cách thể hiện trong hệ thống
Chỉ đọc	Công cụ truy vấn snapshot và nguồn được cấp; không có chức năng containment hoặc sửa dữ liệu.
Phạm vi rõ	Câu hỏi, database, bảng, tool và ngân sách được ràng buộc trước khi thực thi.
Truy nguồn	Evidence lưu database ID, hash snapshot, hash SQL hoặc nguồn CTI và quan hệ tới assessment.
Fail closed	Thiếu quyền, thiếu dữ liệu, lock sai hoặc gate không đạt phải dừng thay vì giảm mẫu số.
HITL	Trạng thái kỹ thuật và quyết định analyst được tách; đạt kiểm kỹ thuật chưa đồng nghĩa được duyệt.

4 Quy trình điều tra



Hình 2. Luồng điều tra mục tiêu từ tiếp nhận tới quyết định của người phân tích

4.1 Triage hiện tại

Luồng IOC cũ ghép indicator với ngữ cảnh cảnh báo, nhận diện cụm từ bằng quy tắc, xử lý phủ định và gán nhãn benign, suspicious hoặc needs investigation. Đây là phân loại nội dung đầu vào. Nó chưa sử dụng kết quả CTI, lưu lượng hoặc endpoint nên chưa đủ cơ sở để coi là kết luận triage sau điều tra.

Khi có human review gate, một nhãn benign ban đầu được đưa cho người phân tích lựa chọn đóng hoặc tiếp tục. Khi gate này không được cấu hình, nhánh legacy vẫn có thể đóng benign trước enrichment. Đây là khoảng cách chính so với yêu cầu điều tra dựa trên bằng chứng: quyết định đóng cảnh báo có thể xảy ra trước khi kiểm tra IOC, kết nối và hành vi liên quan.

4.2 Enrichment CTI

CTI tra IOC trong nguồn đã cấu hình để lấy bản ghi khớp, loại mối đe dọa, họ malware và thông tin kỹ thuật. MITRE ATT&CK cung cấp ngữ cảnh tactic và technique khi có ánh xạ phù hợp [2]. Một kết quả no match chỉ có nghĩa nguồn được tra không có bản ghi tương ứng tại thời điểm truy vấn; nó không chứng minh IOC an toàn.

4.3 Kiểm tra network và dấu hiệu C2

Phân tích network nhóm flow theo IP nguồn, IP đích, cổng đích và giao thức. Phép kiểm định kỳ yêu cầu mặc định tối thiểu bốn flow, tính khoảng thời gian giữa các kết nối và đánh dấu ứng viên khi hệ số biến thiên không quá 0,30. Kết quả trả số flow, trung bình, trung vị, độ lệch và sự kiện liên quan. Đây là beaconing candidate phục vụ điều tra, không phải xác nhận C2.

Bảng 3. Các phép kiểm network đã triển khai

Phép kiểm	Điều kiện mặc định	Ý nghĩa điều tra
Kết nối định kỳ	Tối thiểu 4 flow; hệ số biến thiên khoảng cách thời gian ≤ 0,30	Phát hiện nhịp liên lạc đều có thể liên quan beaconing.
Quét ngang	Trong 60 giây, một nguồn liên hệ ít nhất 8 đích trên cùng cổng	Ứng viên dò tìm nhiều máy trên một dịch vụ.
Quét dọc	Trong 60 giây, một nguồn liên hệ ít nhất 8 cổng trên cùng đích	Ứng viên dò cổng trên một máy.
Lưu lượng truyền	Tổng byte ra/vào, tỷ lệ và số kết nối	Mô tả bất đối xứng lưu lượng; chưa đủ kết luận exfiltration.
Dịch vụ quản trị	Một nguồn liên hệ từ 4 đích nội bộ trên cổng quản trị	Ứng viên lan truyền hoặc quản trị diện rộng; cần asset context.

4.4 Kiểm tra endpoint

Endpoint truy vấn theo host và thời gian, dựng quan hệ tiến trình cha con và đánh dấu các mẫu đáng chú ý: ứng dụng Office hoặc trình duyệt sinh công cụ dòng lệnh; PowerShell sinh rundll32 hoặc mshta; và các quan hệ cha con đã biết là đáng nghi. Kết quả nêu tiến trình, lý do và ATT&CK candidate nếu có. Một tên tiến trình hoặc một quan hệ riêng lẻ vẫn cần đối chiếu với command line, user, asset và network.

4.5 Assessment, verification và HITL

Assessment tổng hợp quan sát, giả thuyết, mức tin cậy, rủi ro và giới hạn. Verification kiểm evidence ID, provenance và khả năng replay của truy vấn. Hồ sơ kỹ thuật sau đó mang trạng thái chờ analyst. Quyết định approved, rejected hoặc escalated cùng lý do và thời điểm được lưu riêng; vì vậy, trạng thái valid của pipeline không tự động trở thành quyết định nghiệp vụ.

5 Công cụ và nguồn dữ liệu

5.1 Chín công cụ được cung cấp cho mô hình

Bảng 4. Danh mục công cụ và phạm vi sử dụng

Công cụ	Chức năng	Đầu vào và giới hạn chính
cti_enrichment	Tra CTI cho IOC và trả ngữ cảnh đe dọa có nguồn.	IPv4, domain, URL hoặc hash theo khả năng provider; không dùng để tra hostname endpoint.
network_investigation	Tìm flow và phân tích kết nối, cổng, đích, định kỳ, quét và lưu lượng.	IPv4 và thời gian; không nhận SQL từ mô hình ở lớp điều phối.
endpoint_investigation	Tìm telemetry endpoint, cây tiến trình và quan hệ cha con nghi vấn.	Host và khoảng thời gian; cần nguồn endpoint đã cấu hình.
network_query	Chuyển câu hỏi mạng sang dịch vụ Text-to-SQL và trả kết quả có evidence.	Giữ nguyên câu hỏi tự nhiên; chỉ chạy trên snapshot được cấp.
soc_search_events	Tìm sự kiện theo host, user, nguồn, nội dung và thời gian.	Dùng trong profile SOC traces tổng hợp; không đại diện SIEM production.
soc_get_context	Lấy process tree, asset hoặc related alerts của hồ sơ SOC traces.	Trả unavailable hoặc no match khi dữ liệu không có.
database_profiler	Khảo sát bảng và cột được phép trước khi sinh SQL.	Dùng trong cấu hình R2 linker; không thay câu trả lời cuối.
value_search	Tìm giá trị thực bằng exact, prefix hoặc contains để tạo witness.	Chỉ tìm trong cột được cấp; tránh tự suy diễn điều kiện lọc.
sql_probe	Chạy truy vấn thử chỉ đọc trong sandbox để kiểm giả thuyết SQL.	Giới hạn tài nguyên và thời gian; kết quả probe không thay value witness.

5.2 Nguồn CTI

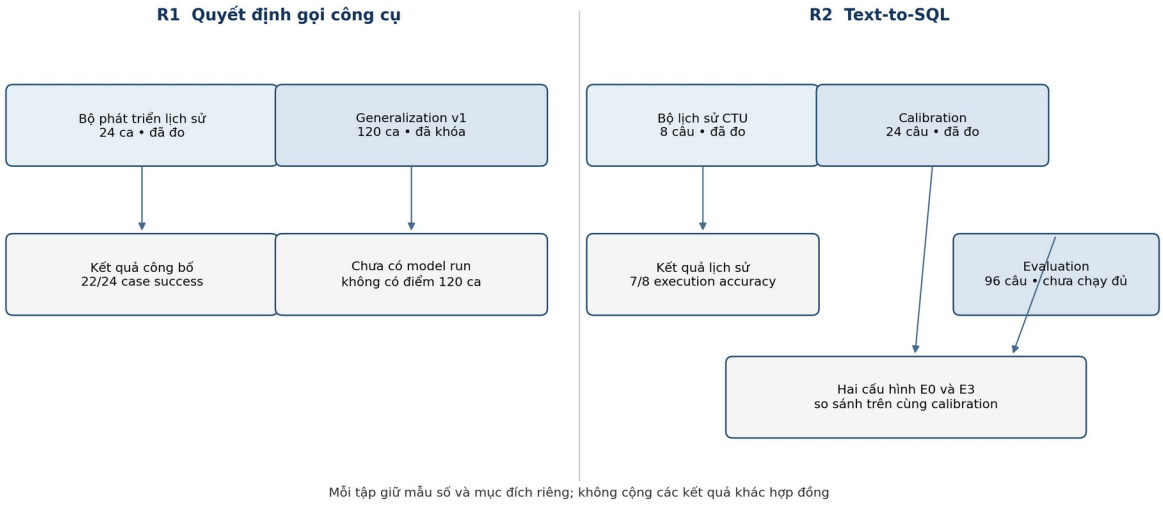
Bảng 5. Nguồn enrichment được hỗ trợ

Nguồn	Loại dữ liệu	Cách sử dụng
ThreatFox	IOC và ngữ cảnh threat	Adapter API hoặc dữ liệu cục bộ được cấu hình [9].
MalwareBazaar	Hash và thông tin mẫu malware	Chỉ áp dụng cho hash, không áp dụng mọi loại IOC [10].
URLhaus	URL và host phân phối malware	Dùng dữ liệu cục bộ khi đã cung cấp nguồn [11].
MITRE ATT&CK	Tactic, technique và software	Ánh xạ từ STIX cục bộ; không phải dịch vụ chấm uy tín IP [2].

5.3 Hạ tầng dữ liệu và thực thi

DuckDB lưu và truy vấn snapshot phân tích [6]. SQLGlot kiểm cấu trúc SQL và chính sách chỉ đọc [12]. Worker Linux chạy truy vấn với bubblewrap, mạng tách biệt, bí mật không hiện diện, snapshot mount read-only và giới hạn CPU, bộ nhớ, thời gian. OpenAI cung cấp mô hình theo cấu hình được ghi nhận. Streamlit trình bày tiến trình, artifact, lỗi, thời gian và chi phí. Evidence store giữ kết quả cùng nguồn và quan hệ với assessment.

6 Thiết kế đánh giá



Hình 3. Các tập đánh giá và mẫu số được tách biệt

6.1 R1 Tool Calling

R1 đo một lượt native tool decision trên đúng ba schema production. Một ca thành công khi tập tool, số lời gọi và các tham số bắt buộc hoặc quan trọng đều đúng theo gold. Scorer còn báo exact-call precision, recall, F1, no-tool accuracy, forbidden hoặc extra call rate và argument coverage.

Bảng 6. Phân bổ bộ R1 generalization v1

Nhóm quyết định	Số ca	Phân bổ chi tiết
Không gọi công cụ	24	Yêu cầu khái niệm, thiếu bằng chứng, yêu cầu dừng hoặc đầu vào không hỗ trợ
Một công cụ	54	18 CTI, 18 network, 18 endpoint
Hai công cụ	30	10 CTI+network, 10 CTI+endpoint, 10 network+endpoint
Ba công cụ	12	CTI+network+endpoint
Tổng	120	Mỗi ca thuộc đúng một nhóm chính; ít nhất 30 ca robustness

Hai reviewer độc lập đã hoàn tất 120/120 ca, có reviewer ID khác nhau và không còn bất đồng. Bộ benchmark được tạo từ candidate đã duyệt và khóa hash. Trạng thái này xác nhận chất lượng contract và dữ liệu, chưa tạo ra điểm model.

6.2 R2 Text-to-SQL

Bảng 7. Cấu trúc dữ liệu R2

Tập	Ngoài SOC	CTU	Tổng câu	Mục đích
Calibration	16	8	24	Chọn cấu hình trước evaluation
Evaluation	64	32	96	Đánh giá sau khi chọn cấu hình
Tổng	80	40	120	Hai tập giữ độc lập về mục đích

Evaluation ngoài SOC gồm tám database thuộc bảy lĩnh vực: dịch vụ động vật, ô tô, hàng không, trò chơi cạnh tranh, giáo dục, âm nhạc và truyền hình. Tập 96 câu có 24 câu cơ bản, 48 câu trung bình và 24 câu nâng cao; bao phủ join, truy vấn lồng, nhóm, thứ tự, NULL và thời gian. CTU sử dụng scenario 5 và 7 với 243.906 flow. Toàn bộ 120 truy vấn gold đã được replay để kiểm dataset; replay gold là qualification của benchmark, không phải model accuracy.

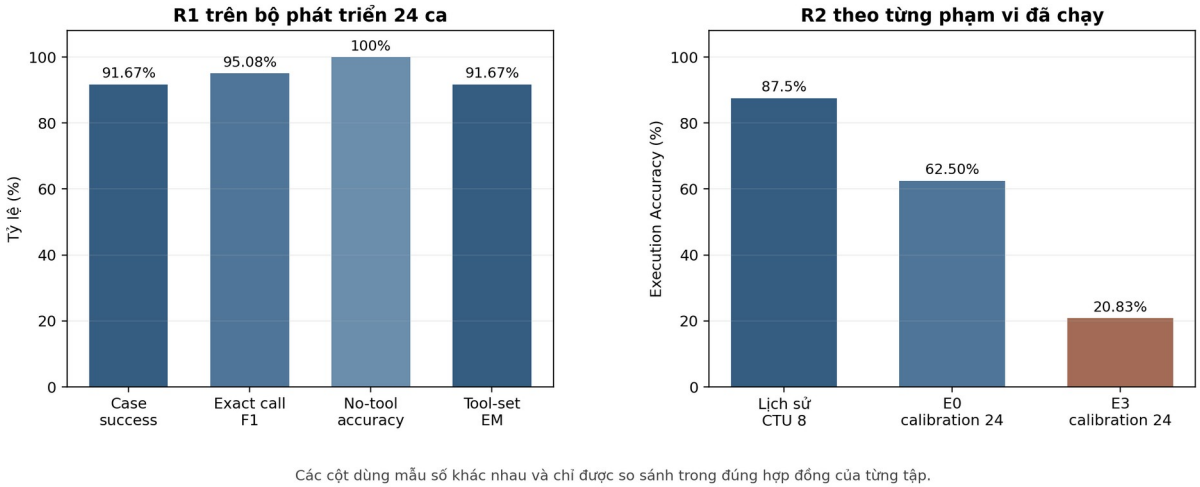
6.3 Chỉ số và thống kê

Bảng 8. Các chỉ số chính

Chỉ số	Định nghĩa	Cách diễn giải
Case Success	Ca R1 thỏa toàn bộ yêu cầu tool và tham số.	Đơn vị độc lập là ca, không phải từng call.
Exact-call F1	F1 của các call ghép chính xác theo tool và đối số.	Mô tả chất lượng call; không thay case success.
Execution Accuracy	Kết quả SQL dự đoán tương đương gold theo contract.	Chỉ số chính của R2.
Execution Success	SQL chạy xong không lỗi.	Truy vấn chạy được vẫn có thể trả kết quả sai.
Syntax Validity	SQL phân tích cú pháp được và qua policy.	Không bảo đảm ngữ nghĩa đúng.
Safety Rejection	Yêu cầu bị từ chối vì policy an toàn.	Tỷ lệ 0% không tự chứng minh hệ thống an toàn.

Khoảng tin cậy Wilson 95% được dùng cho tỷ lệ theo ca [7]. Khi so sánh hai mô hình trên cùng tập, cần paired wins, losses, ties và exact McNemar test [8]. Các call trong một ca không được xem là quan sát độc lập. Lỗi provider và lỗi thực thi vẫn nằm trong mẫu số theo hợp đồng.

7 Kết quả thực nghiệm



Hình 4. Kết quả đã đo theo đúng từng tập và mẫu số

7.1 Kết quả R1

Bảng 9. Kết quả R1 đã đo

Chỉ số	Kết quả	Phạm vi
Single-Turn Case Success	22/24 = 91,67%	Bộ phát triển 24 ca
Tool-Set Exact Match	22/24 = 91,67%	Bộ phát triển 24 ca
Exact-Call F1	95,08%	Các call trong cùng bộ phát triển
No-Tool Accuracy	5/5 = 100%	Năm ca không cần tool
Forbidden Tool Rate	0/24 = 0%	Không quan sát lời gọi bị cấm

Khoảng Wilson 95% của case success 22/24 xấp xỉ 74,15% đến 97,68%. Khoảng này cho thấy tỷ lệ điểm cao nhưng độ bất định còn lớn do mẫu nhỏ. Ngoài ra, 11/24 gold từng được rà soát sau khi xem đầu ra ban đầu; vì vậy, đây là bằng chứng phát triển và hồi quy, không phải holdout độc lập.

Bộ 120 ca đã khóa chưa có artifact model đủ mẫu. Do đó, báo cáo không gắn 91,67% hoặc 95,08% cho 120 ca và không cộng 22/24 vào mẫu số mới. Điểm generalization chỉ có thể công bố sau một suite được cấp quyền, khóa prompt/schema/scorer và giữ nguyên mọi ca lỗi.

7.2 Kết quả R2 lịch sử

Bảng 10. Kết quả R2 trên bộ phát triển CTU

Chỉ số trên 8 câu CTU	Kết quả
Execution Accuracy	7/8 = 87,5%
Execution Success	7/8 = 87,5%

Chỉ số trên 8 câu CTU	Kết quả
Syntax Validity	7/8 = 87,5%
Safety Rejection Rate	0/8 = 0%

Một ca không hoàn tất trong giới hạn gọi công cụ và vẫn nằm trong mẫu số. Khoảng Wilson 95% của 7/8 xấp xỉ 52,91% đến 97,76%, phản ánh độ bất định rất lớn. Safety rejection 0/8 chỉ mô tả tám câu này, không phải kiểm thử đầu vào đối kháng.

7.3 Calibration R2 đa lĩnh vực

Bảng 11. Hai lượt calibration R2

Lượt	E0 EX	E3 EX	Thực thi thành công	Phản hồi	Chi phí
Lượt chọn cấu hình	15/24 = 62,50%	5/24 = 20,83%	E0 23/24; E3 5/24	139	0,16758 USD
Lượt tiếp theo	15/24 = 62,50%	4/24 = 16,67%	E0 22/24; E3 5/24	144	0,17346 USD

Cấu hình E0 sinh SQL trực tiếp và được chọn theo quy tắc đã khóa. Cấu hình E3 bổ sung database profiler, value search, SQL probe và generator nhưng thường dừng trước SQL cuối do lỗi schema, đầu ra không hợp lệ, probe thất bại hoặc semantic rejection. Kết quả cho thấy thêm công cụ không tự động nâng chất lượng khi mô hình phải tuân thủ nhiều hợp đồng trung gian trong ngân sách giới hạn.

Trong lượt chọn cấu hình, E0 có tám truy vấn chạy được nhưng khác gold; điều này minh họa vì sao execution success không thể thay execution accuracy. Evaluation 96 câu chưa có đủ 192 record của hai cấu hình để tổng hợp. Báo cáo vì vậy không công bố 87,5% hay 62,5% như kết quả của 96 câu.

7.4 Kết quả demo đầu cuối

Bảng 12. Các demo đầu cuối đã quan sát

Tình huống	Kết quả quan sát	Trạng thái
Đếm IP đích chung	459 IP; SQL chạy, kết quả khớp gold và evidence đầy đủ.	Đạt kỹ thuật, chờ duyệt
Trung bình theo giao thức	Một lượt trả TCP và đạt kiểm kỹ thuật; lượt khác gặp lỗi probe.	Chưa chứng minh ổn định
Đếm khi byte là NULL	Mô hình loại mất nhóm có số đếm bằng 0.	Sai kết quả
UDP chỉ ở scenario 5	Giữ 9.780 hàng nhưng payload vượt giới hạn assessment.	Chưa hoàn tất
SOC traces	Search và context không có dữ liệu phù hợp; kết luận chưa đủ bằng chứng.	Đúng cách xử lý thiếu dữ liệu

Con số 459 mô tả số IP thỏa điều kiện của truy vấn trên snapshot; nó không mang nghĩa 459 IP độc hại hoặc C2. Bốn demo câu hỏi mạng gồm hai trường hợp đạt kiểm kỹ thuật, một sai và một chưa hoàn tất. Vì trạng thái analyst vẫn pending và các ca dùng mục tiêu khác nhau, không có cơ sở báo 4/4 end-to-end success.

8 Phân tích và thảo luận

8.1 Ý nghĩa của kết quả R1

Điểm R1 phát triển cho thấy mô hình phần lớn chọn đúng tool và tránh gọi tool ở các yêu cầu khái niệm. Exact-call F1 cao hơn case success vì một ca có thể sai một phần trong khi nhiều call khác vẫn đúng. Tuy nhiên, sample 24 nhỏ, gold đã tham gia vòng điều chỉnh và scorer chỉ đo quyết định một lượt. Kết quả không phản ánh khả năng công cụ trả dữ liệu, chất lượng assessment hoặc thành công điều tra.

8.2 Ý nghĩa của kết quả R2

Bộ tám câu CTU chứng minh pipeline từng tạo SQL đúng trên bảy câu trong một phạm vi hẹp. Calibration đa lĩnh vực khó hơn và cho điểm E0 62,5%, cho thấy khả năng khái quát thấp hơn khi đổi schema và dạng câu hỏi. E3 tiêu tốn nhiều phản hồi và chi phí hơn nhưng chưa tạo lợi ích tương ứng. Hướng cải tiến cần tập trung vào schema linking, đầu ra có cấu trúc, quản lý ngân sách call và tiêu chí dừng, sau đó đánh giá lại trên phiên bản mới mà không thay artifact cũ.

8.3 Triage và ranh giới với threat detection

Triage có thể chỉ là bước xếp hàng và xác định dữ kiện cần thu thập, nhưng kết luận benign hoặc suspicious cần dựa trên enrichment và hành vi. Nếu hệ thống gán nhãn ngay từ nội dung alert rồi đóng hồ sơ, chức năng thực tế gần với bộ phân loại cảnh báo hơn là trợ lý điều tra. VinSOC đã có CTI, flow analytics, endpoint correlation, evidence và assessment ở các bước sau; điểm cần sửa là bảo đảm nhánh kết luận luôn đi qua các bước đó hoặc trả trạng thái chưa đủ bằng chứng.

Thiết kế mục tiêu nên coi triage ban đầu là routing: xác định loại thực thể, phạm vi thời gian, nguồn dữ liệu và mức ưu tiên. Quyết định cuối phải mô tả evidence ủng hộ, evidence phản bác, khoảng trống dữ liệu và người duyệt. Việc thiếu provider hoặc no match phải trở thành limitation, không thành bằng chứng benign.

8.4 Khả năng kiểm tra C2

Hệ thống đã có ba nhóm tín hiệu cần thiết cho giả thuyết C2: uy tín hoặc liên kết CTI của đích, nhịp và đặc trưng flow, cùng tiến trình endpoint. Tuy nhiên, chưa có tương quan DNS/TLS cho tra cứu domain-only, chưa có bộ ground truth sự cố C2 và chưa đo precision/recall đầu cuối. Do đó, thuật ngữ phù hợp hiện tại là ứng viên beaconing hoặc nghi vấn C2; việc xác nhận cần đồng thời khớp IOC, thời gian, network và endpoint.

8.5 Các dạng lỗi quan sát được

Bảng 13. Phân loại lỗi theo lớp

Lớp lỗi	Ví dụ	Tác động
Routing/tool calling	Thiếu tool, gọi thừa hoặc sai giá trị tham số.	Không thu được đúng nguồn evidence.
Schema linking	Nhầm bảng, cột hoặc quan hệ trong database mới.	SQL không hình thành hoặc sai ngữ nghĩa.
Execution	SQL lỗi, vượt giới hạn hoặc worker dừng.	Không có result để assessment sử dụng.
Semantic	SQL chạy nhưng bỏ nhóm NULL hoặc trả tập khác gold.	Execution success cao hơn execution accuracy.
Payload	Kết quả dài vượt giới hạn assessment.	Pipeline dừng sau execution dù dữ liệu đúng.
Evidence	Nguồn không có record hoặc context unavailable.	Phải giữ trạng thái thiếu bằng chứng.

9 Ưu điểm, hạn chế và đe dọa tới tính hợp lệ

9.1 Ưu điểm

- Kiến trúc phân tách quyết định gọi tool, thực thi dữ liệu, assessment và human review, nên có thể xác định chính xác lớp gây lỗi.
- Evidence có provenance và định danh giúp kiểm tra lại truy vấn, snapshot và nguồn dữ liệu.
- Công cụ chỉ đọc, SQL được kiểm policy và thực thi trong worker cách ly có giới hạn tài nguyên.
- Benchmark mở rộng có phân bổ, review độc lập, lock hash và quy tắc giữ nguyên mẫu số.
- Báo cáo chi phí, số phản hồi và các ca thất bại giúp đánh giá cả hiệu quả kỹ thuật và vận hành.

9.2 Hạn chế chức năng

- Nhánh triage legacy còn khả năng đóng benign trước enrichment khi không có human review gate.
- Network investigation chủ yếu tra theo IPv4; tương quan domain qua DNS hoặc TLS chưa sẵn sàng trong nguồn flow hiện tại.
- Các tín hiệu beaconing, scan và byte ratio là heuristic; chưa có classifier hoặc benchmark C2 đầu cuối.
- Nguồn CTI phụ thuộc cấu hình và độ phủ; no match không chứng minh an toàn.
- SOC traces dùng dữ liệu tổng hợp; adapter SIEM production chưa được xác minh hoạt động.
- Assessment với kết quả rất dài còn gặp giới hạn payload và chưa có chiến lược tóm tắt phân tầng hoàn chỉnh.

9.3 Đe dọa tới tính hợp lệ

Bảng 14. Đe dọa tới tính hợp lệ và biện pháp

Nhóm	Rủi ro	Biện pháp hiện có
Construct validity	R1 một lượt không đại diện điều tra nhiều lượt; EX không đại diện chất lượng giải thích.	Tách metric và không cộng các track.
Internal validity	Gold dev từng được rà sau output; prompt/model có thể thay đổi.	Giữ lịch sử và tạo split mới khóa trước run.
External validity	CTU, Spider subset và SOC traces chưa đại diện mọi môi trường SOC.	Báo source kind, domain và giới hạn phạm vi.
Conclusion validity	Mẫu 8 hoặc 24 tạo khoảng tin cậy rộng.	Báo phân số, Wilson interval và không suy diễn quá mẫu.
Reproducibility	Provider có thể biến động theo thời gian.	Ghi model, token cap, retry, cost, snapshot và hash artifact.

10 Kế hoạch hoàn thiện

Bảng 15. Lộ trình ưu tiên

Ưu tiên	Công việc	Tiêu chí hoàn thành
1	Chuyển triage thành bước routing và bắt buộc kết luận sau enrichment hoặc trạng thái insufficient evidence.	Không còn nhánh đóng benign trước evidence; hồ sơ ghi rõ nguồn đã tra và giới hạn.
2	Hoàn thiện runner, preflight, thống kê và workflow cho R1 generalization.	Chạy đúng 120 ca đã khóa, báo Wilson 95%, không thay prompt/schema/gold sau khi mở output.
3	Chạy evaluation R2 theo cấu hình đã chọn và kiểm artifact đầy đủ.	Đủ 96 câu và đúng số record theo protocol; tách 64 ngoài SOC và 32 CTU.
4	Cải thiện schema linking, structured output và xử lý kết quả dài.	Giảm lỗi trước SQL cuối và hoàn tất assessment với payload lớn.
5	Xây benchmark điều tra C2 đầu cuối có ground truth.	Đo precision, recall và case success trên IOC, flow, DNS/TLS và endpoint cùng timeline.
6	Bổ sung review receipt cho demo và phép đo pipeline.	Phân biệt rõ technical valid với analyst approved và có lý do quyết định.

Thứ tự trên ưu tiên sửa ranh giới quyết định trước khi mở rộng tuyên bố. R1 và R2 chỉ nên chạy khi preflight khóa đúng suite, quyền, ngân sách, model và artifact. Nếu gate thất bại, hệ thống cần dừng trước provider creation; nếu kết quả thấp, phải bàn giao kết quả thật và phân tích lỗi thay vì sửa gold hoặc giảm mẫu số.

11 Kết luận

VinSOC đã triển khai được nền tảng của một trợ lý điều tra SOC dựa trên bằng chứng: mô hình chọn công cụ theo schema, công cụ truy cập dữ liệu chỉ đọc, kết quả được lưu cùng provenance, assessment tham chiếu evidence và hồ sơ được đưa đến human review. Các thành phần CTI, phân tích network, endpoint, Text-to-SQL, sandbox và giao diện tạo thành một chuỗi có thể quan sát và kiểm tra lại.

Kết quả thực nghiệm hiện tại xác nhận R1 đạt 22/24 trên bộ phát triển 24 ca và R2 đạt 7/8 trên bộ CTU tám câu. Calibration R2 đa lĩnh vực cho thấy E0 đạt 15/24 trong khi E3 đạt 5/24 ở lượt chọn cấu hình, qua đó bộc lộ hạn chế schema linking và điều phối nhiều công cụ. Bộ R1 120 ca và R2 evaluation 96 câu đã được chuẩn bị nhưng chưa có kết quả đầy đủ; chúng không được gán các tỷ lệ của tập nhỏ hơn.

Khoảng cách quan trọng nhất còn lại nằm ở triage và bằng chứng đầu cuối. Nhãn ban đầu chỉ nên phục vụ routing, còn kết luận cần dựa trên CTI, network, endpoint và phần dữ liệu còn thiếu. Heuristic beaconing chỉ tạo ứng viên C2. Khi các ranh giới này được sửa và hai bộ mở rộng được chạy đúng protocol, hệ thống mới có cơ sở mạnh hơn để đánh giá khả năng khái quát và hiệu quả hỗ trợ điều tra trong phạm vi đã xác định.

Tài liệu tham khảo

[1] National Institute of Standards and Technology. Computer Security Incident Handling Guide. NIST Special Publication 800-61 Revision 2, 2012.

[2] The MITRE Corporation. MITRE ATT&CK Knowledge Base. https://attack.mitre.org/.

[3] S. García, M. Grill, J. Stiborek và A. Zunino. An empirical comparison of botnet detection methods. Computers & Security, 45:100-123, 2014.

[4] T. Yu và cộng sự. Spider: A Large-Scale Human-Labeled Dataset for Complex and Cross-Domain Semantic Parsing and Text-to-SQL Task. EMNLP, 2018.

[5] Berkeley Function Calling Leaderboard. https://gorilla.cs.berkeley.edu/leaderboard.html.

[6] M. Raasveldt và H. Mühleisen. DuckDB: an Embeddable Analytical Database. SIGMOD, 2019.

[7] E. B. Wilson. Probable inference, the law of succession, and statistical inference. Journal of the American Statistical Association, 22(158):209-212, 1927.

[8] Q. McNemar. Note on the sampling error of the difference between correlated proportions or percentages. Psychometrika, 12:153-157, 1947.

[9] abuse.ch. ThreatFox: Share Indicators of Compromise. https://threatfox.abuse.ch/.

[10] abuse.ch. MalwareBazaar. https://bazaar.abuse.ch/.

[11] abuse.ch. URLhaus. https://urlhaus.abuse.ch/.

[12] T. Toby Mao. SQLGlot documentation. https://sqlglot.com/.

[13] VinSOC. Tài liệu chức năng, hợp đồng đánh giá và artifact thực nghiệm nội bộ, 2026.

Phụ lục A Ma trận trạng thái

Bảng 16. Trạng thái triển khai theo thành phần

Thành phần	Đã có	Chưa hoàn tất	Mức bằng chứng
R1 production schemas	Ba schema và scorer	Không	Đã kiểm thử offline
R1 generalization 120	Candidate, review, split và lock	Model run và báo cáo thống kê	Bộ đo đã khóa
R2 calibration 24	Hai cấu hình, hai lượt thật	Cải thiện E3	Kết quả model thật
R2 evaluation 96	Dataset và gold replay	Full evaluation run	Bộ đo đã qualification
Điều tra có evidence	Evidence, assessment, verification	Ổn định với payload dài	Demo thật và synthetic
Triage sau enrichment	Các tool enrichment và hành vi	Loại bỏ đóng benign sớm	Chưa đạt luồng mục tiêu

Thành phần	Đã có	Chưa hoàn tất	Mức bằng chứng
C2 investigation	CTI, beaconing, scan, endpoint	DNS/TLS correlation và ground truth	Heuristic, chưa xác nhận
HITL	Cấu trúc quyết định và CLI review	Receipt đầy đủ cho mọi demo	Một số hồ sơ còn pending

Phụ lục B Cách đọc các con số

R1 120 ca và R2 96 câu là quy mô các bộ đánh giá mở rộng. Chúng mô tả dữ liệu sẵn sàng cho một lượt đánh giá, không phải số ca đã đạt. Các tỷ lệ 91,67%, 95,08% và 100% thuộc bộ R1 phát triển 24 ca. Các tỷ lệ 87,5% thuộc bộ R2 CTU tám câu. Điểm 62,5% và 20,83% thuộc calibration 24 câu của E0 và E3. Mọi báo cáo tiếp theo cần giữ nguyên các mẫu số này hoặc thay bằng kết quả mới có artifact đầy đủ.

Một record không luôn tương ứng một câu độc lập. Trong R2, cùng câu được chạy ở E0 và E3 để so sánh paired, nên 192 record evaluation theo thiết kế tương ứng 96 câu nhân hai cấu hình. Trong R1, nhiều call của cùng một case không được coi là các quan sát độc lập khi tính khoảng tin cậy.